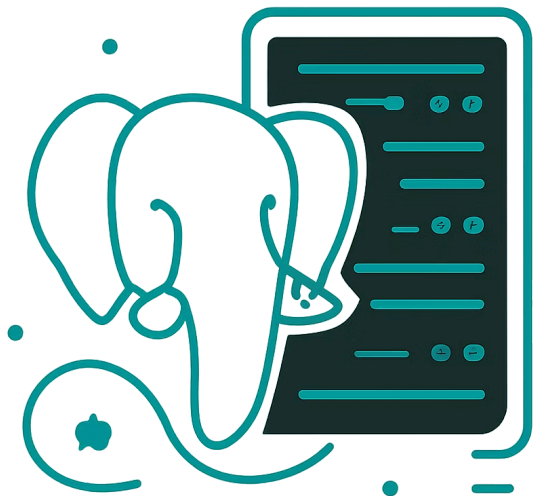




Công Nghệ & Thiết Kế Hệ Thống

Tổng quan kiến trúc kỹ thuật — Database, Real-time Engine, DevOps, Bảo mật và Thiết kế CSDL cho hệ thống thương mại điện tử Nextech.

PostgreSQL 16 + Prisma ORM v7



PostgreSQL — 37 models, schema-first

- ACID compliance — thiết yếu cho thanh toán & hóa đơn
- Decimal cho tiền tệ — tránh floating-point error
- @@unique constraint — một serial chỉ thuộc một order
- JSON fields linh hoạt mở rộng

Prisma ORM

- Type-safe từ DB đến code — lỗi schema phát hiện lúc compile
- Migration tự động: prisma migrate dev / deploy
- Relation queries include / select mạnh mẽ

❏ Tất cả giá dùng Decimal(12,2), không dùng float.

Real-time Engine — Sockets

Tự dựng WebSocket Server

Giao thức tương thích Pusher, chi phí thấp hơn SaaS.

- Container riêng trong Docker network
- Backend trigger event qua Pusher SDK
- Frontend nhận event qua `pusher-js`
- Nginx reverse proxy: `wss://api.nextech.io.vn/app/*` → `soketi:6001`

Private Channel `private-user.{userId}`

- Mỗi user chỉ nhận thông báo của chính mình
- Xác thực qua `/notifications/auth` (JWT verify riêng)

- ✔ Độ trễ **<10ms**, không giới hạn concurrent connections, không tốn phí SaaS.



Docker Compose & Container Architecture

frontend_app

Nginx serving React build (port 3000)

admin_app

Nginx serving React build (port 3001)

backend_app

Express.js API (port 5000)

soketi_app

WebSocket server (port 6001)

postgres_db

PostgreSQL 16 (port 5432)

Nginx Reverse Proxy

1 entry point duy nhất (port 443), route theo subdomain: `nextech.io.vn`, `admin.nextech.io.vn`, `api.nextech.io.vn`. Let's Encrypt SSL tự động.

Multi-stage Builds

Dockerfile tối ưu kích thước image — chỉ copy `node_modules` production.

Users & Authentication

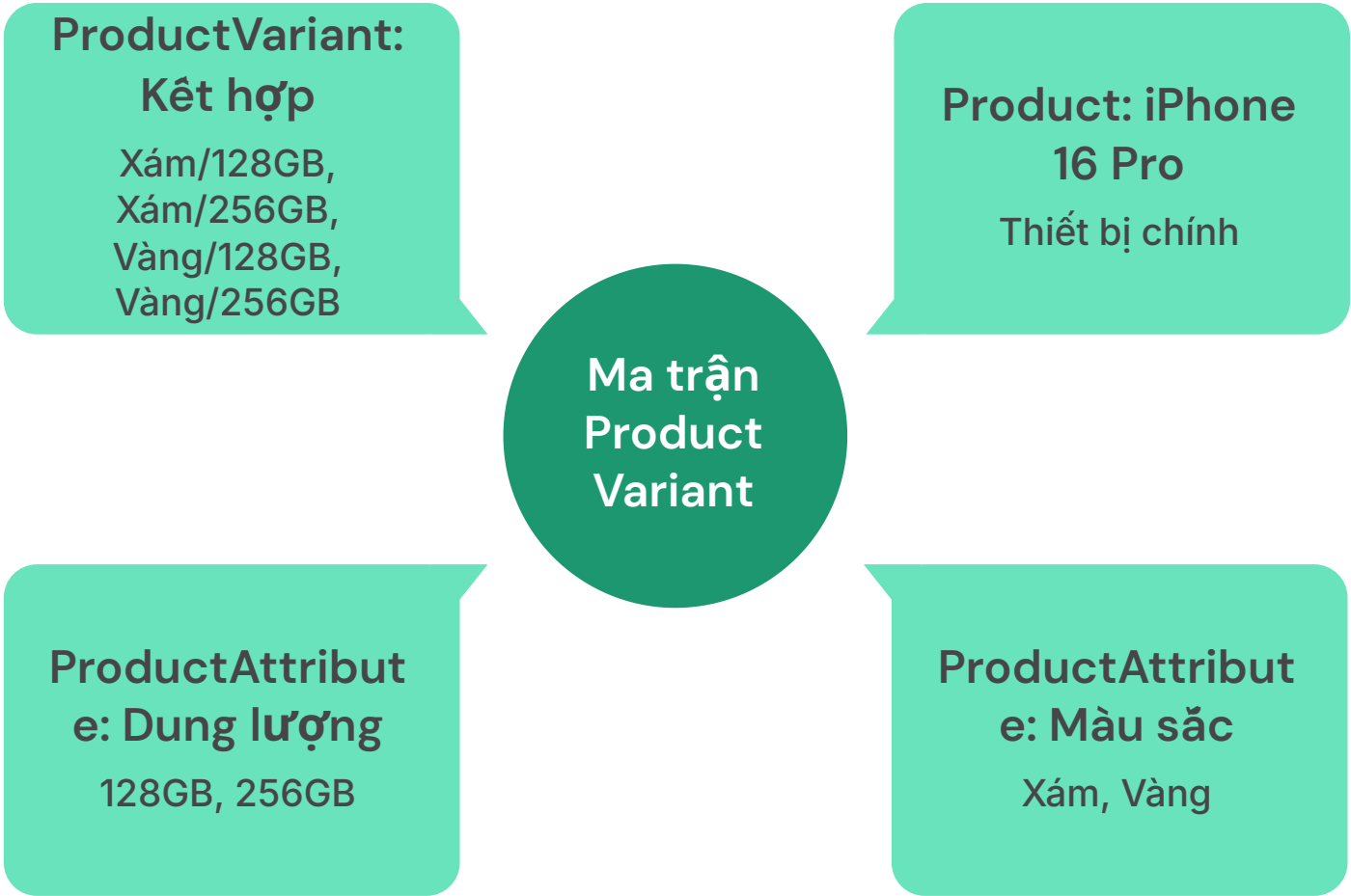
User	Khách hàng: email, password hash, OAuth, profile
Admin	Quản trị viên riêng biệt, không public register
OAuthAccount	Liên kết Google/Facebook (provider + providerId)
RefreshToken	JWT refresh token có expiry, liên kết User/Admin
RevokedToken	Blacklist token thu hồi — chống replay attack
PasswordResetToken	Token đặt lại mật khẩu có expiry

Đặc điểm bảo mật

- Admin và User là **2 bảng riêng** — không lộ admin endpoint
- RefreshToken có expiresAt — tự động dọn dẹp định kỳ
- RevokedToken ghi thời gian thu hồi — không thể dùng token cũ

Products & Catalog

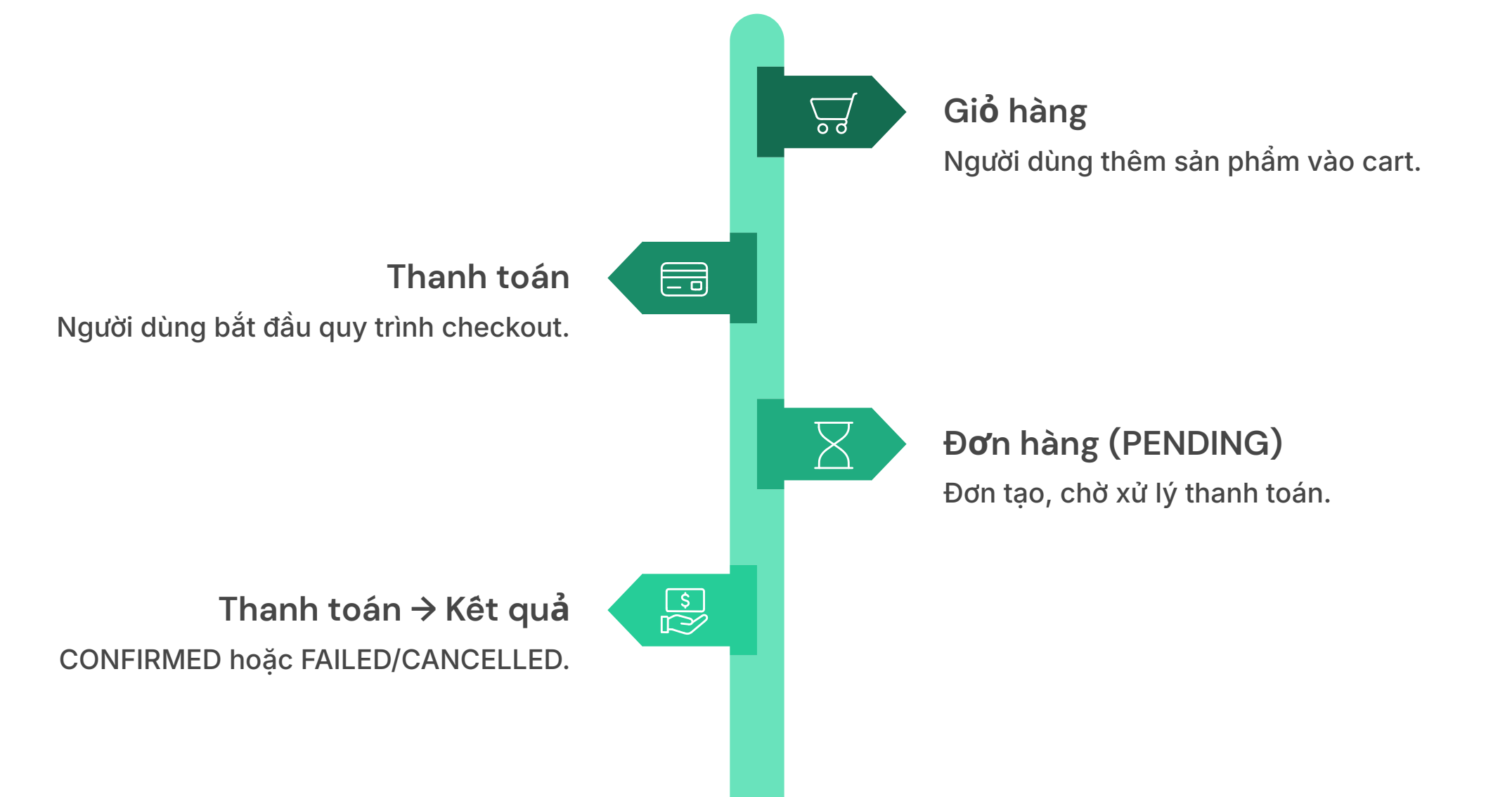
Ma trận cấu hình sản phẩm (Product Variant Matrix)



Kết hợp các thuộc tính tạo ra các variant sản phẩm duy nhất.

Product Tên, mô tả, giá gốc, brand, category	ProductImage Gallery ảnh, ảnh đại diện, sort order
Brand Thương hiệu: Apple, Samsung, Dell...	Category & Tag Phân loại và gắn thẻ sản phẩm, bài viết

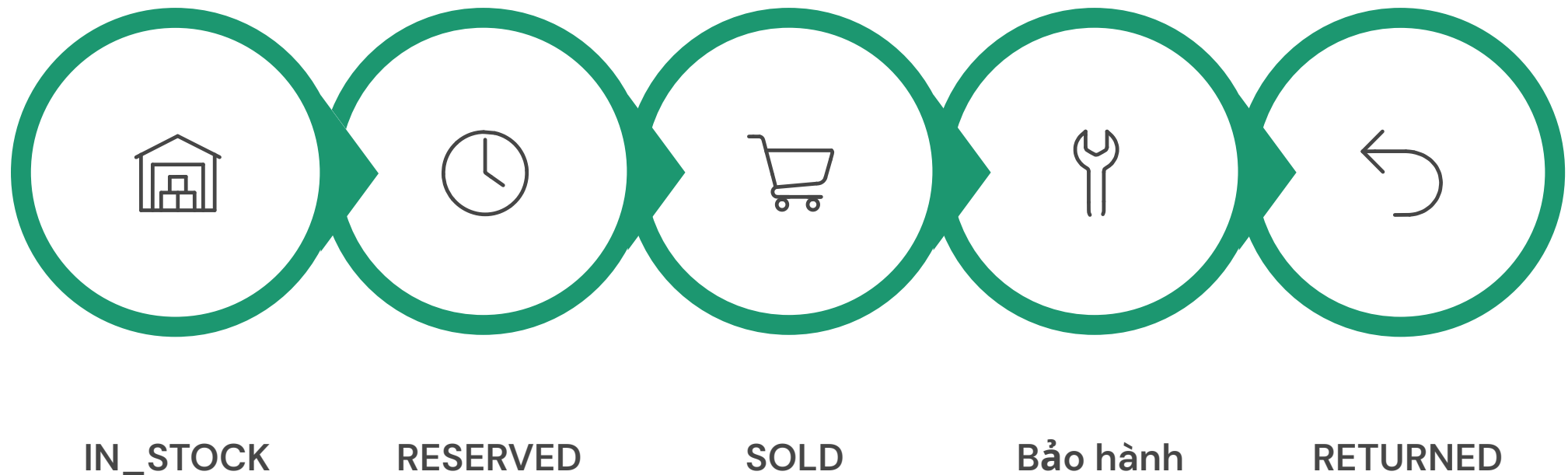
Orders & Cart



Luồng đơn hàng từ giỏ đến thanh toán và xác nhận.

Cart / CartItem Giỏ hàng theo user, có expiry	Order Status: PENDING → PROCESSING → CONFIRMED → SHIPPING → DELIVERED → CANCELLED	OrderItem Snapshot giá tại thời điểm mua	Coupon / CouponUsage Mã giảm giá + ghi lại ai đã dùng — chống dùng lại
Review Đánh giá sản phẩm sau khi nhận hàng			

Serial IMEI & Kho Hàng



Vòng đời SerialUnit từ nhập kho đến bán và bảo hành.

Models chính

- **Supplier** — Nhà cung cấp: tên, liên hệ, địa chỉ
- **StockImport** — Phiếu nhập kho: thời gian, tổng số lượng
- **SerialUnit** — IMEI/Serial duy nhất: status, liên kết StockImport & OrderItem

Ràng buộc & Tra cứu

- `@@unique([serialNumber, orderItemId])` — một serial chỉ gán một order item
- Tra cứu bảo hành: IMEI → SerialUnit → OrderItem → Order → User

Tiện Ích & Vận Hành



Notification

Thông báo real-time: user, message, type, read status



AIChatMessage

Lịch sử hội thoại chatbot AI (role: user/assistant)



FailedEmail

Hàng đợi email lỗi — tự động retry qua cron job



Post

Bài viết tin tức công nghệ, có scheduled publish



ShopSettings

Cấu hình toàn cục: lowStockThreshold, orderAlertThreshold, VAT



Category & Tag

Phân loại bài viết — tái sử dụng với Product Category

Bảo Mật — JWT & Pusher Auth

Access/Refresh Token Rotation

- Access Token: **1h** · Refresh Token: **7d** — lưu HttpOnly Cookie
- Chống XSS: Token không lưu localStorage
- Chống CSRF: Cookie SameSite: Lax + ký request qua `COOKIE_SECRET`

Pusher Private Channel Auth

Endpoint `POST /notifications/auth` bypass middleware:

1. Thử `access_token` trước → user channel
2. Fallback `admin_access_token` → admin channel
3. Cả hai sai → **401 Unauthorized**

